

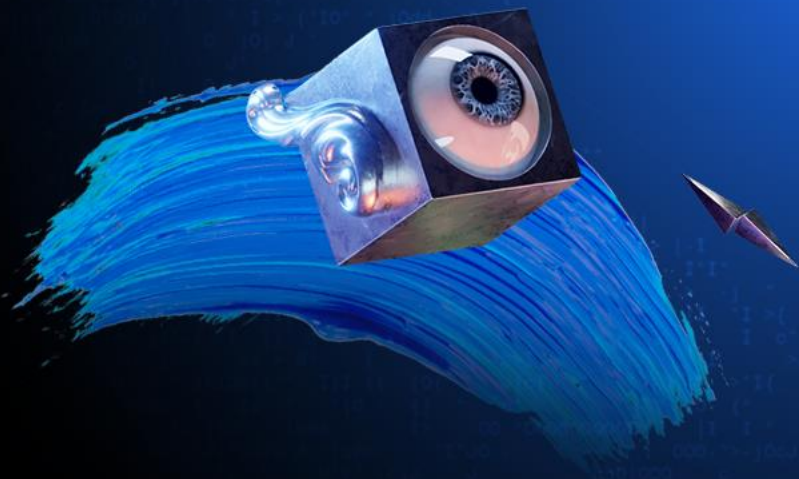
OFFZONE
2026

Опыт построения ИИ-пентестера

Сергей Колесников
CICADA8



Только опыт, не гайд



Сергей Колесников

Директор продуктового
портфеля и сервисов CICADA8

Ex BI.ZONE, ex ByteDance

OSCP, OSWE, CDP, CDE, CREST ...



@tr3harder

Не будет: ML/DL, синтетика



План доклада

01 Первые шаги в разработке

02 Проблемы

03 Построение архитектуры

04 Компоненты

05 Результаты и выводы



2025

Начало разработки

AI модуль в ЕТМ для
верификации уязвимостей

2026

Тестирование новых
гипотез

Подбор библиотек, тесты
open source решений

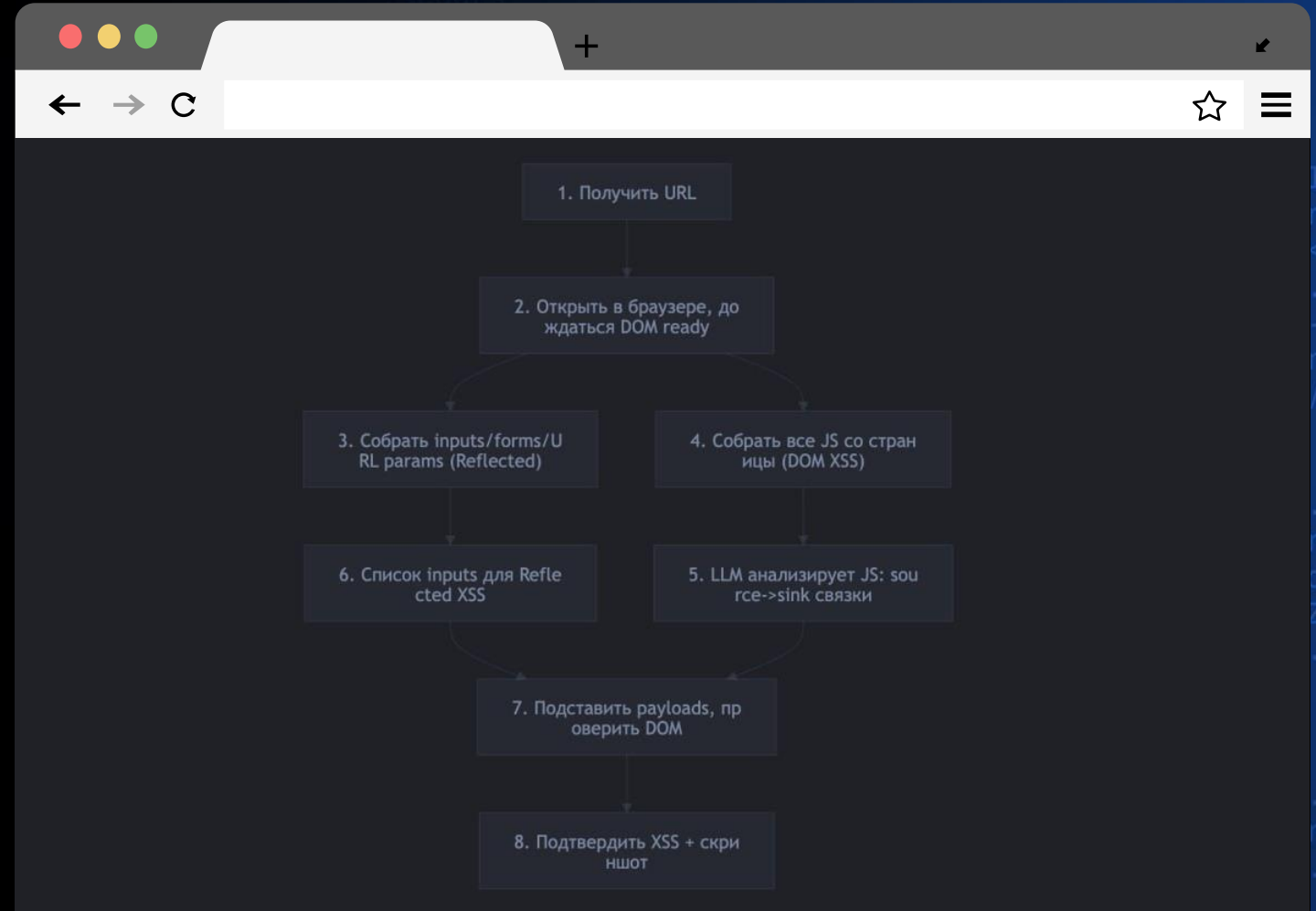
Сейчас

Собственный harness

Выбор своего подхода,
техническое обогащение

Первые шаги

- Начали разработку AI модуля для ETM в 2025 году. **Задача:** непрерывное тестирование периметра
- Строили детерминированные графы под разные классы уязвимостей
- Много работали с промптами
- Бенчмарки на публичных задачах и лабораторных работах (XBOW, PortSwigger, HackTheBox)



Первые шаги

Были первые результаты, а вместе с ними выводы и проблемы:

- Архитектура зависит от LLM
- Расширение в текущей парадигме - очень сложно

Reflected XSS Confirmed

Detail	Information
Target URL	[REDACTED]
Injection Vector	GET parameter reason (reflected in HTML via innerHTML)
Reflection Context	HTML text – the value is inserted directly into <div id="reason-line"> with innerHTML. No encoding or sanitization is applied.
Payload Used	<svg onload=document.title='XSS_CONFIRMED'></svg> (HTML-text payload)
Verification Method	verify_xss_execution – checked document.title (DOM title) → executed (title changed to XSS_CONFIRMED). Screenshot captured as proof.
Severity	High – arbitrary JavaScript execution on a corporate-controlled block page.
Impact	An attacker can run any JavaScript in the context of the corporate network, potentially stealing credentials, bypassing security controls, or performing actions on behalf of the user.
Proof Artifact	Screenshot (artifact ID: screenshot_artifact) showing page title XSS_CONFIRMED.
Finding ID	xss_ed2562c7 (saved via save_xss_finding).

5. Сохранена находка (save_xss_finding):

- Тип уязвимости: **reflected**
- URL: [REDACTED]
- Источник: param: state
- Контекст: redirect_url (instanceUrl) via location.replace
- Payload: javascript:document.title='XSS_CONFIRMED'//
- Proof: page-tab_1.png (скриншот с найденным маркером)

Две крайности

Крайность 1:

детерминированный пайплайн

Убивает смысл использования LLM -
ее креативность

Крайность 2:

излишняя свобода

Для LLM свобода = возможность
“уйти пораньше”



Переход на другую архитектуру



Все быстро менялось и к концу 2025 года:

- Модели стали значительно “умнее”
- Появились скиллы (<https://agentskills.io/home>)
- Стало появляться больше материалов и ресерчей
 - MCP, community-written скиллы, чужой опыт
 - <https://github.com/SimoneAvogadro/android-reverse-engineering-skill>
 - <https://github.com/elementalsouls/Claude-BugHunter>
 - <https://github.com/dreadnode/capabilities>

Чего казалось достаточно

01 Браузер и консоль

02 Мощная модель и скиллы

03 Память и стейт

Проблемы

Проблема #1: Непрозрачность работы

- Трейсов очень много, видимости хода запуска спустя несколько часов работы мало

Проблема #2: Обеспечить глубокое и широкое покрытие одновременно

- Fan out $\neq$ deep hunt
- “Find all the bugs, don’t make mistakes” - не работает (к сожалению)

Проблема #3: Продолжительность работы

- Агенты ленивые и галлюцинируют
- Агенты хотят поскорее закончить задачу и выйти

Что оказалось необходимо

Skills

Техническое
подкрепление агента в
процессе тестирования

State

Описывает состояние
текущего запуска по цели

Memory

Помогает не теряться в
контексте и не тратить
токены на уже
проделанную ранее работу

Tools

Браузер, HTTP-tool, shell,
OOB-kit, MCP, APK

Auth

OTP / SMS / Email-шлюзы,
инфраструктура с живыми
сессиями

Observability

Гипотезы, трафик с
распределением по
воркерам, контроль скоупа

State

Структурированный key-value с явной схемой:

- Воркеры
- Эндпойнты и покрытие
- Гипотезы
- Модель цели
- Lifecycle находок

https://example.com

COST

<mask>

TOTAL TOKENS

<mask>

in <mask> · out
<mask>

DURATION

999h

2000-01-01
00:00:00

TERMINATION

running

26 worker rounds

MODEL

<model>

worker <model>

HYPOTHESES

X CONFIRMED

Y TESTED

Z QUEUED

N BLOCKED

M REJECTED

TASKS

X RUNNING

Y QUEUED

Z BLOCKED-ON-DEPS

N COMPLETED

M DONE

K FAILED

TARGET MODEL

► Roles (9)

► Capabilities (15)

► Attack chains (1 · 4 nodes · 2 edges)

ENDPOINT COVERAGE 327 ENDPOINTS · 94 OBJECTS · 237 INVARIANTS

METHOD	HOST / PATH	STATUS	AUTH	SOURCE
POST	/v3/links.content		guest+csrf-gated	page.js getSharedThreadUnauthenticated
POST	/v3/links.comment		authenticated	page.js postCommentWithIDToken
POST	/v3/links.commentToken		public	page.js
POST	/v3/links.open		authenticated	inventory+live
POST	/v3/links.joinTeam		authenticated	page.js
POST	/v3/links.joinTeamToken		public	page.js
GET	/v3/csrfToken.create		public	page.js _csrfToken
GET	/ping		public	fuzz

- Уже описанные практики <https://agentskills.io/skill-creation/best-practices>
- Больше размер - не лучше качество скилла
- Готовых plug-and-play скиллов почти не существует под ваши задачи
 - Методология, а не чек лист
 - Способы и поведение при проверке, а не список нагрузок
 - Всегда нужна адаптация под собственный harness
- Модели “умнеют”:
 - меньше “технического” описания типовых уязвимостей, больше методологий по охвату и рекомендаций к полноте покрытия
 - консолидация скиллов важнее их количества в системе

Observability

- Кастомная атрибуция трафика по агентам
 - Хранение всех отправленных запросов и ответов на них с возможностью HTTPQL, evidence проверки и эксплуатации уязвимости
- ScoreJudgement, контроль “безопасности” действий через внешний LLM
- Lifecycle гипотез
- Сбор трейсов, метрик

16:55:26 STATE.QUEUE_HYPOTHESIS · COMPLETED

```
{ "claim": "shared-thread HTML sanitizer (DOMPurify with ALLOW_UNKNOWN_PROTOCOLS:true + custom afterSanitizeAttributes hook _fixSourceUrls/_makeAllLinksOpenInNewTab that rewrite src/srcset/href/cid POST-sanitization) can be bypassed to achieve DOM XSS when a crafted email/shared-thread body is rendered via dangerouslySetInnerHTML. leading to account
```

19:27:26 STATE.MARK_HYPOTHESIS · COMPLETED

```
{ "hypothesis_id": " ", "status": "rejected", "inline_evidence": " "
```

```
base also returns count:0 (own data only). Ownership scoping holds; not an IDOR.", "reason": "param does not override JWT tenant filter"}
```

HYPOTHESIS DETAIL

confirmed

graphql_https_ GraphQL_mutations_on_ allow_anonymo · graphql · medium

GraphQL mutations on allow anonymous or authenticated data modification, or GraphQL query batching/aliasing enables authz bypass or rate-limit bypass

WORKED BY: task_default_001 · default bug-graphql

Workers

- Сегментация ролей
- Разница набора тулов/скиллов
- Выбор моделей под цели

```
@enqueue_worker(...,  
    goal="",  
    task=[],  
    skills=[],  
    hypoteses=[],  
    ...)
```

19:18:13 STATE.ENQUEUE_WORKER · COMPLETED

```
type=default skills=['bug-mass-assignment']  
Test registration mass-assignment on (hvd-register-massassign-003).
```

[open worker task_default_005 →](#)

[go to trace ↗](#)

task_idor_028 · idor

[← run](#)

[trace →](#)

STATUS

completed

FINDINGS

1

3 leads · 14 dead-ends

DURATION

30m17s

exit 0

SCHEMA

valid

5 missing paths

Memory

- Event-sourced memory с индексацией
- Короткая - прогресс в текущем запуске
- Длинная - между разными запусками
 - Индексация для удобного поиска, дедупликация
 - Найденные уязвимости, покрытые гипотезы
 - Общее знание о приложении
 - Связанные приложения (в т.ч. мобильные)
- Knowledge Base
 - Скиллы, методология
 - CVE по стеку приложения

01 Recon

Активный -
выделенные воркеры

- JS, .APK

Пассивный

- HTTP-трафик

02 Browser

- Антибот
- Работа с DOM,
не клики по картинке

03 MCP

- ООВ-
взаимодействия,
инструменты, ...

Auth

- База: самые интересные баги - за аутентификацией:
 - Запуск без сессий = 0-1-2 находки на таргет
 - Запуск с сессией = 7-8
- Обязательный минимум: 2 сессии на запуск
- SMS / Email шлюзы
- Кастомные шлюзы под OAuth приложения
- Хранение и продление сессий

03:01:19 STATE.RECORD_SESSION - COMPLETED

```
{"session id": [REDACTED], "role": "user a", "tokens json": {"token": [REDACTED], "ey [REDACTED], "auth_header": [REDACTED], "password": [REDACTED], "method_summary": "1 (raw JWT, no Bearer). [REDACTED], "source": [REDACTED]}
```

AUTH SESSIONS (8)

SESSION	STATUS	EVIDENCE
user_acct_a	?	JWT works on REST, not GraphQL
user_acct_b	?	JWT works on REST, not GraphQL
online_<masked>	?	—

Что держит агента?

01 Стейт

Агент не знает условий выхода

02 Воркеры

Агент не дергает
воркеров -
информация об их
работе передается в
conversation

03 Промпт гигиена

Агент не должен знать
что он часть
измеряемой системы

*иначе он начнет искать
способы выхода чтобы
быстрее закончить
работу*

Что еще не упустить?

01 Экономия токенов

- Harness должен потреблять минимум токенов, максимум на исследование приложения и верификацию уязвимостей
- Кэширование токенов

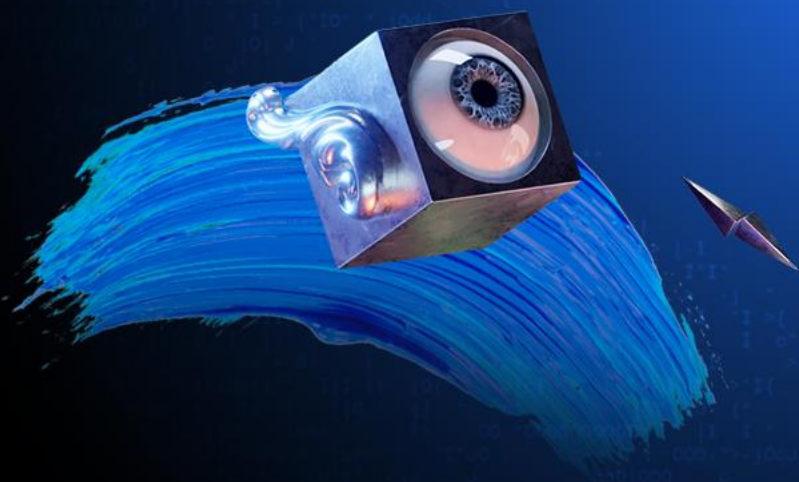
02 Scope enforcement

- Проблема: агент может переходить на соседние или out-of-score приложения
- Решение: Создание отдельного решения по контролю (LLM + проху)

03 Матрица API

- Полнота покрытия
- Запрет проверки чужих объектов

Верификация



Верификация

- Отдельный процесс верификации critic воркерами
- False positive отнимает время у оператора, false negative будет обнаружен в последующих запусках
- Каждая находка - начало цепочки, а не “победа” агента
- “Ты триажер. Багхантер пытается тебя обмануть...”

pending_critic · race · medium · authenticated

Inventory double-booking

FOUND BY: **orchestrator** CRITIC: **task_finding-critic_010**

discard · **critic: discard** · other · high · unauthenticated

Open redirect via client-side ref

FOUND BY: **task_idor_018** · idor · **bug-open-redirect** CRITIC: **task_finding-critic_014**

submit · **ssrf** · high · unauthenticated

Full-read SSRF REST proxy via [redacted] returns response body inline, no IP filtering →

Full-read server-side proxy — cloud metadata credential theft, k8s API access, internal network scanning with full response body return. Most severe SSRF variant.

FOUND BY: **orchestrator**

Различия моделей

- Разные модели находят РАЗНЫЕ баги
- Одна и та же цель, одни и те же условия - разные находки:

GLM 5.2

3 crit / 1 high / 5 medium / 2
low

Opus 4.8

1 crit / 1 high / 3 medium / 5
low

Различия моделей (по типам уязвимостей)

Тип уязвимости	Модель, % от находок (~)			
	Qwen 3.6	GLM 5.2	Opus	GPT
IDOR / Auth	35	50	45	30
Business Logic	10	20	25	30
SSRF	10	10	10	5
Client-Side	25	10	15	20
Info disclosure, other	20	10	5	15

Различия моделей (по выборке лаб)

01

Тестирование небольших моделей с 200к контекстом на лабах:

- Qwen3.6-35B - 73% pass rate
- Sonnet 4.8 - 80% pass rate

02

Тестирование небольших моделей на живых таргетах:

- Qwen3.6-35B - 1-2 находки за ран
- Sonnet 4.8 - 5-6 находок

03

Другие протестированные модели:

- Qwen 3.5-27B, gpt-120b-oss
- <https://huggingface.co/Jackrong>
- Qwopus3.6-27B-v2-FP8
- Qwen3.5-27B-v3
- Qwen3.5-27B-Claude-4.6-Opus-Reasoning-Distilled

Результаты so far



1400+

находок было засабмичено агентом

Первый круг “нейрослопа”

600+

находок было одобрено агентом-критиком перед дедупликацией

Второй круг “нейрослопа”

200+

подтвержденных оператором уязвимостей (~):

16% critical, 30% high

27% medium, 17% low, 10% info

Как делали бенчмарки

- Раньше - "WOW my agent solved 90% of XBOW labs!!! 🤩🤩🤩"
- Сейчас - "where to find labs which are not in training dataset..."

Почему все равно бенчим?

- Экономия перед реальными запусками
- Возможность пробовать новые модели

Как теперь тестировать свои наработки?

- Писать собственные лабораторные работы и harness вокруг них
- Искать только что вышедшие лабы/задания/машины

Сложности разработки

Бутылочное горлышко - тестирование

- “Плохие” гипотезы все равно потребляют токены
- Для подтверждения и опровержения гипотезы должно пройти несколько ранов

“И за это мы платим 200 баксов...”:

• Вижу две большие новости – одна хорошая, две плохие. Гляну глубже:

• Да, такое собирается и это о...но крутая идея



Обучение моделей

Гипотеза

Обучить Qwen 3.6
на трейсах Orus

Результат

- Ванильный Qwen: 73% решений по выборке лаб и 30-40 шагов
- Файнтюн Qwen: 41% и 100-120 шагов соответственно

Проблема

модель переняла рассуждения и механику, но не способность к решению

Пока продолжаем эксперименты 😊

Что двигает разработку сейчас

“No need to be a Mythos to do offensive security” by Patrick Ventuzelo
@ Le Hack 2026

“If a large model finds a 0-day with 90% probability, and a small model with 50% probability, but the small model costs 10x less, it is better to use the small model.” by live overflow @ [hacktron.ai](https://www.hacktron.ai)

<https://www.hacktron.ai/blog/why-mythos-doesnt-matter-for-us>

https://fuzzinglabs.com/wp-content/uploads/2026/06/Le-Hack-2026-Keynote-_No-Need-to-be-a-Mythos-to-do-Offensive-security-Patrick-Ventuzelo_-FuzzingLabs.pdf

OFFZONE
2026

Спасибо!
Вопросы?



OFFZONE 2026

CICADA⁸



@CICADA8_RU

Приходите :)

